

Top 10 web hacking techniques of 2018 - nominations open



James Kettle
Director of Research
[@albinowax](#)



Published: Thursday, 3 January 2019 at 14:43 UTC

Updated: Friday, 4 September 2020 at 14:23 UTC



Update: voting is now live. Please head over and [place your vote](#).

Nominations are now open for the top 10 new web hacking techniques of 2018.

Every year countless security researchers share their findings with the community. Whether they're elegant attack refinements, empirical studies, or entirely new techniques, many of them contain innovative ideas capable of inspiring new discoveries long after publication.

And while some inevitably end up on stage at security conferences, others are easily overlooked amid a sea of overhyped disclosures, and doomed to fade into obscurity.

As such, each year we call upon the community to help us seek out, distil, and preserve the very best new research for future readers.

As with [last year](#), we'll do this in three phases:

- **Jan 1st:** Start to collect community nominations
- **Jan 21st:** Launch community vote to build shortlist of top 15
- **Feb 11th:** Panel vote on shortlist to select final top 10

Last year we decided to prevent conflicts of interest by excluding PortSwigger research, but found the diverse voting panel meant we needed a better system. We eventually settled on disallowing panelists from voting on research they're affiliated with, and adjusting the final scores to compensate. This approach proved fair and effective, so having [checked with the community](#) we'll no longer exclude our own research.

To nominate a piece of research, either [use this form](#) or reply to [this Twitter thread](#).

Feel free to make multiple nominations, and nominate your own research, etc. It doesn't matter whether the submission is a blog post, whitepaper, or presentation recording - just try to submit the best format available. If you want, you can take a look at past years' top 10 to get an idea for what people feel constitutes great research.

You can find previous year's results here:

[2006](#), [2007](#), [2008](#), [2009](#), [2010](#), [2011](#), [2012](#), [2013](#), [2014](#), [2015](#), [2016/17](#).

Nominations so far

Here are the nominations so far. We're making offline archives of them all as we go, so we can replace any that go missing in future. I'll do a basic quality filter before the community vote starts.

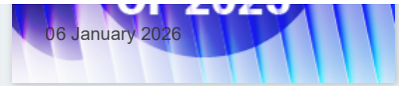
- [How I exploited ACME TLS-SNI-01 issuing Let's Encrypt SSL-certs for any domain using shared hosting](#)
- [Kicking the Rims - A Guide for Securely Writing and Auditing Chrome Extensions | The Hacker Blog](#)
- [EdOverflow | An analysis of logic flaws in web-of-trust services.](#)
- [OWASP AppSecEU 2018 – Attacking "Modern" Web Technologies](#)
- [PowerPoint Presentation - OWASP AppSec EU18 WordPress.pdf](#)
- [Scratching the surface of host headers in Safari](#)
- [RCE by uploading a web.config – 003Random's Blog](#)
- [Security: HTTP Smuggling, Apsis Pound load balancer | RBleug](#)
- [Piercing the Veil: Server Side Request Forgery to NIPRNet access](#)
- [inputzero: A bug that affects million users - Kaspersky VPN | Dhiraj Mishra](#)
- [inputzero: Telegram anonymity fails in desktop - CVE-2018-17780 | Dhiraj Mishra](#)
- [inputzero: An untold story of skype by microsoft | Dhiraj Mishra](#)
- [Neatly bypassing CSP – Wallarm](#)
- [Large-Scale Analysis of Style Injection by Relative Path Overwrite - www2018rpo_paper.pdf](#)
- [Beyond XSS: Edge Side Include Injection :: GoSecure](#)
- [GitHub - HoLyVieR/prototype-pollution-nsec18: Content released at NorthSec 2018 for my talk on prototype pollution](#)
- [Logically Bypassing Browser Security Boundaries - Speaker Deck](#)
- [Breaking-Parser-Logic-Take-Your-Path-Normalization-Off-And-Pop-0days-Out](#)
- [Web Cache Deception Attack - YouTube](#)
- [Duo Finds SAML Vulnerabilities Affecting Multiple Implementations | Duo Security](#)
- [#307670 Difference in query string parameter processing between Hacker News and Keybase](#)
- [Chrome extension spawns chat to incorrect user](#)
- [lanmaster53.com](#)

- [Beyond XSS: Edge Side Include Injection :: GoSecure](#)
- [Scratching the surface of host headers in Safari](#)
- [#309531 Stored XSS in Snapmatic + R★Editor comments](#)
- [InsertScript: Adobe Reader PDF - Client Side Request Injection](#)
- [\\$36k Google App Engine RCE - Ezequiel Pereira](#)
- [MKSB\(en\): CVE-2018-5175: Universal CSP strict-dynamic bypass in Firefox](#)
- [#341876 SSRF in Exchange leads to ROOT access in all instances](#)
- [reCAPTCHA bypass via HTTP Parameter Pollution – Andres Riancho](#)
- [Data Exfiltration via Formula Injection #Part1](#)
- [Read&Write Chrome Extension Same Origin Policy \(SOP\) Bypass Vulnerability | The Hacker Blog](#)
- [Firefox uXSS and CSS XSS - Abdulrahman Al-Qabandi](#)
- [Server-Side Spreadsheet Injection - Formula Injection to Remote Code Execution - Bishop Fox](#)
- [Bypassing Web-Application Firewalls by abusing SSL/TLS | 0x09AL Security blog](#)
- [Evading CSP with DOM-based dangling markup | Blog](#)
- [Save Your Cloud: DoS on VMs in OpenNebula 4.6.1](#)
- [CRLF Injection Into PHP's cURL Options – TomNomNom – Medium](#)
- [Practical Web Cache Poisoning | Blog](#)
- [#317476 Account Takeover in Periscope TV](#)
- [A timing attack with CSS selectors and Javascript](#)
- [VPN Extensions are not for privacy](#)
- [Exposing Intranets with reliable Browser-based Port scanning | Blog](#)
- [Exploiting XXE with local DTD files](#)
- [A story of the passive aggressive sysadmin of AEM - Speaker Deck](#)
- [Hunting for security bugs in AEM webapps - Speaker Deck](#)
- [ASP.NET resource files \(.RESX\) and deserialisation issues](#)
- [Story of my two \(but actually three\) RCEs in SharePoint in 2018 | Soroush Dalili \(@irsdl\) – سروش دلیلی](#)
- [Beware of Deserialisation in .NET Methods and Classes + Code Execution via Paste!](#)
- [cat ~/footstep.ninja/blog.txt](#)
- [Blog - RCE due to ShowExceptions](#)
- [MB blog: Vulnerability in Hangouts Chat: from open redirect to code execution](#)
- [Blog on Gopherus Tool](#)
- [DNS Rebinding Headless Browsers](#)
- [It's A PHP Unserialization Vulnerability Jim But Not As We Know It](#)

← [Back to all articles](#)

Related Research





Burp Suite

[Web vulnerability scanner](#)
[Burp Suite Editions](#)
[Release Notes](#)

Vulnerabilities

[Cross-site scripting \(XSS\)](#)
[SQL injection](#)
[Cross-site request forgery](#)
[XML external entity injection](#)
[Directory traversal](#)
[Server-side request forgery](#)

Customers

[Organizations](#)
[Testers](#)
[Developers](#)

Company

[About](#)
[Careers](#)
[Contact](#)
[Legal](#)
[Privacy Notice](#)
[Modern Slavery Statement](#)

Insights

[Web Security Academy](#)
[Blog](#)
[Research](#)
[Engineering](#)



© 2026 PortSwigger Ltd.

